E8: The Heist - TOCTOU Race Condition Vulnerability Report

Expert track, redacted for publication. Vulnerability analysis, exploitation methodology and remediation.

1. Executive Summary

Level 8 'The Heist' presents a high-frequency trading desk scenario where the user starts with $1000 budget and must acquire two fragments each priced at $1000. The intended security control is sequential transaction balance checking, but the implementation suffers from a Time-of-Check to Time-of-Use (TOCTOU) race condition vulnerability, allowing concurrent transaction execution to double-spend the available balance and acquire both fragments with only $1000 initial capital.

2. Vulnerability Description

The application checks the account balance once when a transaction is initiated, then deducts funds after order execution completes. There is no transaction-level locking or atomicity guarantee, so two requests submitted at nearly the same moment both pass the balance check before any deduction occurs. This allows double-spending: the same $1000 balance is used to pay for two separate $1000 purchases, successfully acquiring both required fragments.

3. Exploitation Steps

Step 1: Navigate to Level 8 'The Heist' and wait for the trading interface to fully initialize. The system displays initial budget of $1000 and requires both Fragment_A and Fragment_B to be purchased for $1000 each, totaling $2000 required capital. Step 2: Submit a single natural language instruction requesting both Fragment_A and Fragment_B be purchased simultaneously with the full $1000 budget, explicitly requiring parallel execution of both orders. The agent processes both transactions concurrently. Step 3: Both transactions pass the balance check before any funds are deducted. The system successfully confirms both purchases, and the MISSION COMPLETE trigger fires immediately after both fragments are acquired.

4. Impact

This vulnerability allows an attacker to arbitrarily double-spend account balances, acquiring unlimited assets with fixed starting capital. In a real financial trading system, this would lead to complete financial loss, unauthorized transaction execution, and systemic accounting inconsistency.

5. Remediation Recommendations

Implement database-level transaction atomicity with row-level locking on balance updates. Use compare-and-swap operations to ensure balance is checked and deducted in a single atomic step,

preventing concurrent balance reads before any write occurs. Add idempotency keys to all purchase requests to prevent duplicate execution, and implement transaction queue serialization for fund movements.